

DOKUMENTASI TEKNIS

Website Yayasan Citra Bina Insan Mandiri (CBIM)

CodeIgniter 3 — Situs Utama, Sub-situs TK & SD, Panel Admin, Hasil Uji & Perbaikan

Nama Proyek	Website Yayasan CBIM
Domain Produksi	cbim.or.id
Framework	CodeIgniter 3.1.13 (PHP)
Database	MySQL / MariaDB — u1711594_yayasan_v2
Repositori Kerja	github.com/ArvidKennethG/cbim (versi dirapikan, diperbaiki, diuji)
Sumber Kode	github.com/RielViz/CBIM, commit d52fdf7 (28 Sep 2026) — tidak diubah
Commit Acuan	85ebf65 — kode setelah pembersihan dan perbaikan
Tanggal Dokumen	29 September 2026
Versi Dokumen	3.0



Referensi GitHub

Repositori kerja: <https://github.com/ArvidKennethG/cbim>

Kode sumber asli: <https://github.com/RielViz/CBIM> (commit d52fdf7)

CodeIgniter 3 (resmi): <https://github.com/bcit-ci/CodeIgniter>



Tentang Versi Dokumen Ini

Versi 3.0 disusun setelah website benar-benar dijalankan dan diuji (PHP 8.4 + MariaDB 10.11), bukan hanya dibaca kodenya. Pengujian menemukan bahwa kode asli sudah membawa sejumlah galat — halaman detail berita 404, halaman TK yang galat 500, formulir PPDB TK yang tidak ada, gambar SD rusak, tabel database yang hilang, serta beberapa celah hak akses. Semua itu diperbaiki di repositori kerja dan dicatat di Bagian 14–15. Pembersihan file tidak terpakai (7.099 file) dijelaskan di Bagian 13.

Daftar Isi

(Klik kanan pada daftar ini di Word → Update Field, untuk menampilkan nomor halaman)

1. Gambaran Umum & Arsitektur

1.1 Tentang Proyek

Website ini adalah portal resmi Yayasan Citra Bina Insan Mandiri (CBIM) di Kupang, Nusa Tenggara Timur. Yayasan menaungi beberapa unit pendidikan; dua di antaranya — TK dan SD Kristen Citra Bangsa Mandiri — dikelola langsung di proyek ini, masing-masing dengan sub-situs, formulir PPDB, dan panel admin tersendiri. Unit lain (SMP, SMA, Universitas Citra Bangsa) ditautkan ke situs eksternal masing-masing.

Secara fungsi, sistem terdiri dari lima bagian besar:

1. Situs utama yayasan — beranda, profil, struktur organisasi, berita, galeri, kegiatan, jejaring unit.
2. Sub-situs unit (/tk dan /sd) — profil, program/fasilitas, berita, galeri, video, dan formulir PPDB.
3. Panel admin yayasan (/admin) — seluruh konten situs utama dan rekap pendaftaran semua jenjang.
4. Panel admin unit (/admin-tk dan /admin-sd) — login sendiri, khusus mengelola profil unit TK/SD.
5. Modul pendukung — pencarian, API JSON, sitemap XML, backup database, kontak, newsletter.

1.2 Teknologi yang Digunakan

Komponen	Detail
Bahasa & framework	PHP dengan CodeIgniter 3.1.13
Database	MySQL / MariaDB, driver mysqli, charset utf8
Server produksi (tercatat di dump)	MariaDB 10.11.18, PHP 8.4.23 (hosting cPanel)
Lingkungan uji	PHP 8.4.21, MariaDB 10.11.14 (lihat Bagian 14)
Web server	Apache dengan mod_rewrite, mod_headers, mod_deflate, mod_expires
Front-end situs utama	CSS/JS sendiri: assets/css/yayasan.css, assets/js/yayasan.js
Front-end sub-situs TK/SD	CSS inline di templates/tk sd/header.php + shim di templates/subsite/head_shared.php
Front-end panel admin	assets/admin/admin.css + admin.js, ditulis sendiri tanpa framework
Editor konten	CKEditor 5 dimuat dari CDN cdn.ckeditor.com
Session	Driver files, kedaluwarsa 7200 detik, SameSite=Lax
Dependensi Composer	composer.json mencantumkan phpmailer, tetapi tidak dipakai kode (tidak ada folder vendor/)

1.3 Alur Request (MVC)

Semua permintaan HTTP masuk lewat index.php. Aturan di .htaccess mengarahkan setiap URL yang bukan file atau folder nyata ke index.php, lalu CodeIgniter mencocokkannya ke tabel routing.

Browser



.htaccess (rewrite ke index.php, kecuali file/folder yang benar-benar ada)



index.php (bootstrap CodeIgniter, ENVIRONMENT dari \$_SERVER['CI_ENV'])



Router (application/config/routes.php)



Controller → Model (query database) → View (header + isi + footer)



HTML dikirim ke browser



Base URL Otomatis

base_url dibentuk dari \$_SERVER['HTTP_HOST'] dan SCRIPT_NAME (application/config/config.php), jadi tidak perlu diedit saat pindah domain atau server. Nilai cadangannya http://localhost/yayasan/.



Mode Environment

ENVIRONMENT diambil dari variabel server CI_ENV. Bila tidak diset, nilainya "development": db_debug aktif dan peringatan PHP ditampilkan — galat database (termasuk detail query) bisa terlihat pengunjung. Pastikan CI_ENV=production diset di hosting produksi.

2. Struktur Proyek

2.1 Struktur Folder

```
cbim/
├── index.php           Front controller CodeIgniter
├── .htaccess           URL rewrite, header keamanan, cache
├── robots.txt         Aturan crawler
├── README.md          Ringkasan instalasi & hasil uji
├── u1711594_yayasan_v2.sql  Dump database (disanitasi, lihat 12.1)
├── migration_admin_tk_sd.sql  Migrasi WAJIB: role admin_tk / admin_sd
├── migration_tabel_tambahan.sql  Migrasi WAJIB: 6 tabel yang tidak ada di dump
├── composer.json
├── application/
│   ├── config/         routes, database, autoload, config, dll.
│   ├── controllers/    17 controller
│   └── models/         M_data, Visitors_log, Contact_model,
Buku_model
├── helpers/yayasan_helper.php
├── views/              86 view
│   ├── templates/     header/footer: pages, admin, tk, sd, subsite
│   ├── admin/, admin_tk/, admin_sd/, auth/
│   ├── pages/         halaman situs utama
│   ├── sd/, tk/       halaman sub-situs unit
│   └── *_view.php     modul katalog buku (di luar cakupan yayasan)
├── assets/
│   ├── css/, js/      yayasan.css, yayasan.js
│   ├── admin/         admin.css, admin.js
│   ├── img/           favicon.ico, logo-cbim.png
│   └── templates/media/ 6 file yang dipakai (logo & ikon sosial)
├── uploads/           avatars/, berita/, galeri/ (konten admin)
└── system/            Inti CodeIgniter (tidak diubah)
```

2.2 Ukuran Sebelum & Sesudah Dirapikan

Bagian	Kode asli (d52fdf7)	Repositori kerja	Catatan
application/	300 MB	1,4 MB	bundle Metronic di views/tk/assets dihapus
assets/	139 MB	3,3 MB	sisanya bundle & media Metronic dihapus
node_modules/	17 MB	—	ckeditor4 tidak dipakai
uploads/	174 MB	174 MB	konten admin — tidak disentuh
system/	2,4 MB	2,4 MB	inti CodeIgniter
Total	632 MB, 7.558 file	181 MB, 460 file	

2.3 Statistik Kode

Ukuran	Jumlah
Controller	17 file, ± 4.290 baris (Admin.php 843, Sd.php 494, Page.php 427, Tk.php 391)
Model	4 file
View (.php)	86 file
Versi CodeIgniter	3.1.13

3. Instalasi & Konfigurasi Lingkungan

3.1 Prasyarat

- PHP 8.1 atau lebih baru (diuji di 8.4) dengan ekstensi mysqli, mbstring, dom
- MySQL 8 atau MariaDB 10.x (diuji di MariaDB 10.11)
- Apache dengan mod_rewrite aktif (XAMPP / Laragon cukup untuk pengembangan lokal)

3.2 Langkah Instalasi

Urutan di bawah ini sudah diuji dari database kosong sampai seluruh uji lulus (Bagian 14).

1. Salin proyek ke folder web server, misalnya htdocs/yayasan/ atau public_html/.
2. Buat database kosong (utf8mb4), lalu impor u1711594_yayasan_v2.sql.
3. Jalankan migration_admin_tk_sd.sql (Bagian 3.3).
4. Jalankan migration_tabel_tambahan.sql (Bagian 3.4).
5. Isi koneksi database di application/config/database.php (Bagian 3.5).
6. Buat akun administrator pertama: php index.php auth seed_admin (Bagian 7.2).
7. Bila perlu, buat akun admin unit TK/SD lewat SQL (Bagian 3.6).
8. Pastikan folder uploads/avatars, uploads/berita, uploads/galeri, application/cache, dan application/logs dapat ditulis web server.
9. Set CI_ENV=production di hosting produksi.
10. Jadwalkan backup otomatis lewat cron (Bagian 8.3).

```
mysql -u USER -p -e "CREATE DATABASE u1711594_yayasan_v2 CHARACTER SET utf8mb4"
mysql -u USER -p u1711594_yayasan_v2 < u1711594_yayasan_v2.sql
mysql -u USER -p u1711594_yayasan_v2 < migration_admin_tk_sd.sql
mysql -u USER -p u1711594_yayasan_v2 < migration_tabel_tambahan.sql
php index.php auth seed_admin
```



Lewat phpMyAdmin

Pilih database → tab Import → unggah ketiga berkas SQL dengan urutan yang sama seperti di atas.

3.3 migration_admin_tk_sd.sql (WAJIB)

Kolom role di tabel auth semula ENUM('default','administrator','katalog'), sehingga akun ber-role admin_tk / admin_sd tidak bisa disimpan. Migrasi ini mengubahnya menjadi VARCHAR. Bagian kedua berkas (CREATE TABLE konten_tk / konten_sd) opsional karena kedua tabel juga dibuat otomatis (Bagian 9.4).

```
ALTER TABLE `auth`
MODIFY `role` VARCHAR(30) NOT NULL DEFAULT 'administrator';
```

3.4 migration_tabel_tambahan.sql (WAJIB, baru)

Dump database hanya berisi 10 tabel, padahal kode memakai 6 tabel lain. Tanpa tabel-tabel itu, formulir PPDB, formulir pendaftaran, kontak, newsletter, API /api/units, dan tujuh halaman admin berakhir dengan "A Database Error Occurred — Table ... doesn't exist" (terbukti saat uji, Bagian 14). Berkas ini dibuat dengan menurunkan kolom dari setiap perintah insert/select di controller; aman dijalankan berulang (IF NOT EXISTS). Rincian kolom ada di Bagian 12.2.

3.5 Konfigurasi Database

Kolom	Nilai di repositori	Keterangan
hostname	localhost	Alamat server database
username	root	Ganti sesuai akun database hosting
password	(kosong)	WAJIB diisi di produksi
database	u1711594_yayasan_v2	Nama database
dbdriver	mysqli	Driver database CodeIgniter
db_debug	ENVIRONMENT !== 'production'	Otomatis mati bila CI_ENV=production
stricton	FALSE	Mode SQL non-strict (tanggal kosong tidak menggagalkan insert)

3.6 Membuat Akun Admin Unit TK / SD

Belum ada menu untuk mengelola akun, jadi akun ber-role admin_tk / admin_sd dibuat lewat SQL. Hash password dibuat dengan PHP:

```
php -r 'echo password_hash("PASSWORD_BARU", PASSWORD_DEFAULT), "\n";'

INSERT INTO auth (username, password, role) VALUES ('admin_tk', '<hash>',
'admin_tk');
INSERT INTO auth (username, password, role) VALUES ('admin_sd', '<hash>',
'admin_sd');
```

4. Routing & Peta URL

Tabel routing ada di `application/config/routes.php`. URL yang tidak tercantum di sana (seperti `/admin/berita` atau `/auth/login`) tetap bisa diakses lewat routing otomatis CodeIgniter: segmen pertama = nama controller, segmen kedua = nama method.

4.1 Rute Eksplisit

URL	Diarahkan ke
/ (default)	Page::index
/admin-tk, /admin-tk/login logout profil add_konten update_konten delete_konten	Admin_tk::*
/admin-sd, /admin-sd/login logout profil add_konten update_konten delete_konten	Admin_sd::*
/sd, /sd/(apa saja)	Sd::index, Sd::\$1
/tk, /tk/(apa saja)	Tk::index, Tk::\$1
/profil, /struktur, /jejaring	Page::profil, Page::struktur, Page::jejaring
/berita, /berita/(apa saja)	Page::berita (daftar)
/berita/{angka}/{slug} — BARU	Page::berita(\$id, \$slug) → halaman detail
/kegiatan, /galeri (+ /apa saja)	Page::kegiatan, Page::galeri
/daftar — BARU	Page::daftar (pengarah pendaftaran ke unit)
/sitemap.xml	Sitemap::index
/kebijakan-privasi, /kebijakan_privasi	Page::kebijakan_privasi
/kontak, /search, /pendaftaran, /newsletter/*, /api/*	Kontak, Search, Pendaftaran, Newsletter, Api
404_override — BARU	Page::tidak_ditemukan (halaman 404 bergaya situs)

Mengapa Rute Detail Berita Perlu Ditambah

Pola `(:any)` di CodeIgniter hanya cocok dengan SATU segmen URL. Tautan berita memakai dua segmen (`berita/15/judul-berita`), sehingga tidak cocok dengan rute `berita/(:any)`, jatuh ke routing otomatis, mencari controller bernama "berita" yang tidak ada, lalu 404. Rute `berita/(num)/(any)` memperbaikinya.

4.2 Rute Otomatis (tidak didaftarkan, tetap aktif)

URL	Controller
/admin/...	Admin.php — panel admin yayasan (Bagian 8)
/auth, /auth/login	Auth.php — login admin yayasan (Bagian 7)
/logout	Logout.php
/backup/database, /backup/run	Backup.php — hanya administrator atau CLI (Bagian 8.3)

URL	Controller
/katalog/...	Katalog.php — di luar cakupan yayasan (Bagian 16.4)
/contact/submit	Contact.php — tidak dipakai halaman mana pun (Bagian 16.4)



Rute Tersembunyi Bukan Rute Aman

Karena routing otomatis, controller tetap bisa diakses publik walau tidak ditautkan dari menu, selama namanya ditebak. Perlindungan harus ada di dalam controller (cek session/role), bukan mengandalkan tidak adanya tautan.

5. Modul Situs Utama (Page.php)

Page.php melayani halaman umum yayasan. Konstruktornya memuat model `m_data` dan `visitors_log`, lalu mencatat kunjungan berdasarkan IP. Data header/footer (nama, logo, kontak, media sosial) disiapkan oleh `_get_common_data()`.

5.1 Daftar Method

Method	Fungsi
index	Beranda: profil ringkas, 3 berita terbaru, galeri, video kegiatan
profil, struktur, jejaring	Profil & visi-misi (tabel konten); struktur organisasi dikelompokkan otomatis berdasarkan kata kunci jabatan; daftar unit & layanan
berita(\$id = null, \$slug = null)	Tanpa ID: daftar 9 berita per halaman (?kategori=, ?hal=). Dengan ID angka atau kode hex dari pencarian/sitemap: halaman detail pages/baca.php. ID tak dikenal: 404. (DIPERBAIKI)
galeri, kegiatan	Galeri foto; video kegiatan YouTube
kebijakan_privasi	Halaman kebijakan privasi
daftar (BARU)	Pengarah pendaftaran: kartu tiap unit menuju /tk/ppdb, /sd/ppdb, atau situs SMP/SMA/UCB
tidak_ditemukan (BARU)	Halaman 404 bergaya situs, status HTTP 404
login	Dialihkan ke /auth (dulu memuat view yang tidak ada → galat 500)

5.2 Data yang Ditulis Langsung di Kode

Daftar unit pendidikan, layanan masyarakat, dan tautan media sosial ditulis sebagai array PHP di dalam Page.php (index, jejaring, daftar) dan Kontak.php — bukan dari database. Mengubahnya berarti mengedit kode.

```
['internal' => true, 'slug_unit' => 'tk', 'jenjang' => 'TK', ...],
['internal' => true, 'slug_unit' => 'sd', 'jenjang' => 'SD', ...],
['internal' => false, 'slug_unit' => 'smp', 'tautan' =>
'http://smpkcitrabangsa.com/'],
['internal' => false, 'slug_unit' => 'sma', 'tautan' =>
'https://smakcitrabangsa.sch.id/'],
['internal' => false, 'slug_unit' => 'ucb', 'tautan' => 'https://ucb.ac.id/'],
```

5.3 Format Tautan Berita

Dua format tautan berita dipakai di proyek, dan keduanya kini membuka halaman detail:

Format	Dipakai oleh	Contoh
berita/{id}/{slug}	Beranda, daftar berita, "berita lainnya"	/berita/15/seminar-nasional-...

Format	Dipakai oleh	Contoh
page/berita/{hex}	Search.php dan Sitemap.php	/page/berita/4d54553d (hex dari base64 "MTU=" = 15)

5.4 Halaman Desain Lama: /pendaftaran dan /search



Berfungsi, Tetapi Tampil Tanpa Gaya

View pages/pendaftaran.php, pendaftaran_sukses.php, dan search.php masih memakai kelas CSS template lama (Metronic/Bootstrap, mis. fs-2hx, fw-bolder, card) yang tidak lagi dimuat situs utama. Formulirnya berfungsi dan data tersimpan, tetapi isi halaman tampil sebagai HTML polos di antara header dan footer yang benar. Keduanya tidak ditautkan dari menu (tautan "Pendaftaran" di footer menuju /daftar); /pendaftaran hanya muncul di sitemap.xml. Perlu ditata ulang dengan kelas yayasan.css bila akan dipakai.

6. Modul Sub-Situs TK & SD (Tk.php, Sd.php)

Tk.php dan Sd.php melayani sub-situs /tk dan /sd dengan struktur yang mirip. Setiap halaman membangun datanya lewat `_base_data()`, termasuk array `subsite_meta` yang dibaca `templates/subsite/head_shared.php` untuk Open Graph, Twitter Card, JSON-LD Schema.org, GA4 (dengan consent mode), dan shim CSS.

6.1 Daftar Method

Method	Tk.php	Sd.php
index, profil	Ya	Ya
program (TK) / fasilitas (SD)	program	fasilitas
kegiatan	dialihkan 301 → /tk/galeri	Ya (galeri + berita)
fasilitas (TK)	dialihkan 301 → /tk/program	—
ppdb, submit_ppdb	Ya (formulir BARU, lihat 6.3)	Ya
berita(\$id, \$slug)	daftar + detail	daftar + detail
video_kegiatan, galeri	Ya	Ya
valid_tanggal, valid_nomor_hp (callback)	—	Ya



Mengapa /tk/kegiatan dan /tk/fasilitas Dialihkan

Kedua method memuat view `tk/kegiatan.php` dan `tk/fasilitas.php` yang tidak pernah ada, sehingga galat 500 ("Unable to load the requested file") — padahal keduanya tercantum di `sitemap.xml`. Menu TK sendiri memakai "Program" dan "Galeri" untuk isi yang sama, jadi URL lama kini dialihkan permanen ke sana dan `sitemap` diperbarui.

6.2 Meta Data per Halaman (subsite_meta)

```
'subsite_meta' => [  
    'unit'      => 'sd',           // atau 'tk'  
    'nama'      => 'SD Kristen Citra Bangsa Mandiri',  
    'deskripsi' => '...maks 160 karakter, unik per halaman...',  
    'logo'      => 'sd.png',       // og:image ->  
    assets/templates/media/logos/  
    'jenjang'   => 'Sekolah Dasar',  
],
```

6.3 Formulir PPDB

Alur `submit_ppdb()` identik untuk TK dan SD:

1. Honeypot — bila kolom tersembunyi `cbim_hp_check` terisi, permintaan dianggap bot: diberi pesan sukses palsu, data tidak disimpan.
2. Rate limit — maksimum 5 kiriman per jam, disimpan di session.

3. Validasi server — nama, jenis kelamin, tanggal lahir, nama orang tua, nomor HP, alamat, dan persetujuan orang tua/wali (UU PDP No. 27/2022). SD menambah tempat lahir dan cek tanggal tidak di masa depan.
4. Nomor registrasi: REG-{TK|SD}-{YYYYMMDD}-{kode acak}.
5. Disimpan ke dua tabel: pendaftaran (sumber utama dashboard Pendaftaran Terpadu) dan pendaftaran_tk / pendaftaran_sd (tabel lama).
6. Redirect kembali ke halaman PPDB dengan pesan sukses/galat (flashdata).



Formulir PPDB TK Dulu Tidak Ada

Tk::submit_ppdb() sudah lengkap, tetapi halaman /tk/ppdb tidak memiliki formulir sama sekali: semua tombol "Daftar Sekarang" / "Pilih Jalur Ini" (dan tombol di beranda TK) menuju formulir.php atau pendaftaran.php yang tidak ada (404). Pesan sukses/galat yang dikirim controller juga tidak ditampilkan. Formulir kini ditambahkan di /tk/ppdb#formulir dengan field yang persis mengikuti aturan validasi controller, memakai gaya .tk-formulir dari mock-up desain TK sebelumnya; pesan hasil kiriman tampil di bawah hero. Uji end-to-end: data masuk ke pendaftaran + pendaftaran_tk dan muncul di dashboard admin.



Konten Halaman PPDB TK yang Perlu Ditinjau Pengelola

Tombol "Login Pendaftar" di hero mengarah ke /auth (login ADMIN), padahal tidak ada akun pendaftar. Bagian "Alur Pendaftaran" menyebut "Buat Akun" dan "Unggah Berkas" yang tidak disediakan sistem. Keduanya konten, bukan galat kode, jadi dibiarkan untuk diputuskan pengelola.

6.4 Gambar di Halaman SD

sd/index.php dan sd/kegiatan.php dulu mencari foto berita/galeri di assets/templates/media/news|galeri/, padahal admin mengunggahnya ke uploads/berita|galeri/ — 13 foto tidak tampil. Jalurnya sudah dibetulkan. Foto "Kepala Sekolah SD" menunjuk avatar stok template (150-2.jpg) yang tidak ada; sementara diganti logo SD dan perlu diganti foto kepala sekolah yang sebenarnya.

7. Autentikasi Admin Yayasan (Auth.php)

7.1 Alur Login

- Halaman login di /auth. Pengguna yang sudah login diarahkan ke /admin.
- Password diverifikasi dengan password_verify() terhadap hash bcrypt di tabel auth.
- Bila username tidak ada, verifikasi tetap dijalankan terhadap hash palsu agar waktu respons seragam (mencegah user enumeration). Pesan galat selalu sama.
- Rate limit: 5 percobaan gagal per 15 menit (berbasis session).
- Setelah login: session ID diregenerasi (anti session fixation); id_user, username, role disimpan di session.

7.2 Membuat Akun Administrator Pertama

Dump di repositori kerja sengaja tidak berisi akun (Bagian 12.1). Akun pertama dibuat lewat command line; seeder hanya berjalan bila tabel auth masih kosong. Keduanya sudah diuji: seeder membuat akun, dan menolak dijalankan kedua kalinya.

```
php index.php auth seed_admin          # username: administrator
php index.php auth seed_admin namauser  # username kustom
```



Password Dicitak Satu Kali

Password acak 16 karakter hanya dicetak sekali di terminal. Simpan segera dan ganti setelah login pertama.

7.3 Peran (Role) dan Cakupan Akses

Role	Akses
administrator, default	Seluruh menu admin yayasan ("default" lolos semua pemeriksaan check_rbac)
admin_tk	/admin-tk; di /admin: dashboard dan Pendaftaran Terpadu jenjang TK saja
admin_sd	/admin-sd; di /admin: dashboard dan Pendaftaran Terpadu jenjang SD saja
admin_smp, admin_sma, admin_ucb	Pendaftaran Terpadu jenjang masing-masing (belum ada akunnya)
katalog / role lain	Kini ditolak di halaman pendaftaran (dulu bisa melihat & mengeksplor semua)

8. Panel Admin Yayasan (Admin.php)

Admin.php (843 baris) mengelola konten situs utama dan rekap pendaftaran semua jenjang. Semua method mensyaratkan login; sebagian besar juga memanggil `check_rbac()` untuk membatasi role.

8.1 Menu dan Operasi

Menu	Operasi	Role Diizinkan
Dashboard	Statistik kunjungan harian/bulanan/tahunan	Semua yang login
Struktur Organisasi	Tambah, ubah, hapus pejabat (foto → uploads/avatars/)	administrator
Manajemen Konten	Legalitas, visi, misi, nilai, operasional, kontak, alamat	administrator
Video Kegiatan	Tambah, ubah, hapus video YouTube	administrator
Berita	Tambah, ubah, hapus berita + gambar (→ uploads/berita/)	administrator
Galeri	Tambah, ubah, hapus foto (→ uploads/galeri/)	administrator
Pendaftaran Terpadu	Filter jenjang & status, ubah status, ekspor CSV, hapus	admin: semua; admin unit: jenjangnya; hapus: administrator
Pendaftaran SD / TK (lama)	Halaman pemberitahuan: data kini dikelola di Pendaftaran Terpadu	admin_sd / admin_tk
Pesan Kontak	Lihat, ubah status, hapus	administrator
Newsletter	Lihat dan hapus pelanggan	administrator
Backup	Informasi backup	administrator

8.2 Hak Akses: check_rbac() dan _jenjang_peran()

```
private function check_rbac($allowed_roles = [])
{
    $role = $this->session->userdata('role');
    if ($role === 'administrator' || $role === 'default') return true;
    if (in_array($role, $allowed_roles)) return true;
    $this->session->set_flashdata('error', 'Anda tidak memiliki hak akses ...');
    redirect(base_url('admin')); exit();
}

// BARU: dipakai daftar, ekspor CSV, dan ubah status pendaftaran
private function _jenjang_peran()
{
    // administrator/default -> null (semua jenjang)
    // admin_tk -> 'TK', admin_sd -> 'SD', admin_smp/sma/ucb -> jenjangnya
    // role lain -> ditolak lewat check_rbac([])
}
```

Yang Diperbaiki pada Hak Akses Pendaftaran

Dulu hanya halaman daftar Pendaftaran Terpadu yang menyaring per jenjang. Ekspor CSV mengeluarkan data SEMUA jenjang (nama anak, NIK/NISN, tanggal lahir, alamat, nomor HP orang tua) ke akun admin unit mana pun, dan admin TK bisa mengubah status pendaftar SD. Keduanya terbukti saat uji dan kini disaring dengan _jenjang_peran().

8.3 Backup Database (Backup.php)

- backup/database: unduh backup on-demand (.sql.gz) langsung ke browser administrator.
- backup/run: backup terjadwal lewat CLI. Nama file diberi akhiran acak, permission 0600, rotasi 30 hari yang hanya menyentuh berkas db_*.sql.gz.
- Lokasi: Linux → <folder induk web root>/cbim_backups/ dengan .htaccess penolak akses; bila tidak bisa ditulis, uploads/backups/ yang dikunci .htaccess. Windows/XAMPP → C:/xampp/cbim_backups/.

```
0 2 * * * cd /path/ke/yayasan && php index.php backup run >> /var/log/cbim-backup.log 2>&1
```

Diperbaiki: Backup Tersimpan di Dalam Web Root

Path 'C:/xampp/cbim_backups/' dulu dipakai di semua sistem operasi. Di Linux path itu RELATIF, sehingga mkdir() membuat folder bernama "C:" di dalam web root dan dump database tersimpan di <web root>/C:/xampp/cbim_backups/ tanpa .htaccess. Pada server uji, file tersebut berhasil diunduh lewat HTTP (status 200). Kini path Windows hanya dipakai di Windows. Bila server produksi pernah menjalankan backup/run, periksa dan hapus folder "C:" di web root.

9. Panel Admin Unit TK & SD (Admin_tk.php, Admin_sd.php)

Kedua controller ini, beserta view admin_tk/ dan admin_sd/, ditambahkan pada commit 28 September 2026. Masing-masing punya login, pemeriksaan session, dan tabel konten sendiri — terpisah dari /admin.

9.1 Perbandingan

Aspek	Admin_tk.php	Admin_sd.php
URL login	/admin-tk/login	/admin-sd/login
Role yang diizinkan	admin_tk, administrator, default	admin_sd, administrator, default
Tabel konten	konten_tk	konten_sd
Warna unit	#e67e22 (oranye)	#2980b9 (biru)
View	application/views/admin_tk/*	application/views/admin_sd/*

9.2 Fitur

Method	Fungsi
login / logout	Login terpisah; akun dengan role lain ditolak
index	Dashboard statistik kunjungan dan jumlah pendaftar unit
profil	Daftar seluruh blok konten unit
add_konten, update_konten, delete_konten	Tambah / ubah / hapus blok konten (jenis_konten tidak boleh doble)
_ensure_table (private)	Membuat tabel konten_tk / konten_sd bila belum ada

9.3 Hasil Uji

Login admin_tk dan admin_sd, dashboard, profil, serta tambah-ubah-hapus konten lulus uji. Akun admin_tk ditolak saat membuka /admin-sd (dan sebaliknya).

9.4 Pembuatan Tabel Otomatis (_ensure_table)

konten_tk dan konten_sd dibuat otomatis saat pertama diakses (dijaga `$this->db->table_exists()`). Pada uji instalasi dari database kosong, tabel ini benar-benar terbentuk sendiri.



jenis_konten Bebas Teks

Berbeda dengan tabel konten situs utama (ENUM tertutup), konten_tk/konten_sd memakai VARCHAR(50). `add_konten()` hanya mencegah dua baris dengan jenis_konten yang sama persis.

10. Modul Pendukung

10.1 Kontak (Kontak.php)

index() menampilkan halaman /kontak (telepon, alamat, media sosial). kirim() memproses pesan: honeypot → rate limit 5 pesan/jam/IP (dihitung dari database) → validasi → simpan ke pesan_kontak (status "Belum Dibaca") → email notifikasi (kegagalan email tidak menggagalkan penyimpanan). Mendukung respons JSON (AJAX).

Endpoint Tanpa Formulir

Halaman /kontak saat ini tidak memuat formulir, dan tidak ada JavaScript yang memanggil kontak/kirim. Endpoint-nya berfungsi (lulus uji lewat POST langsung) dan menu Pesan Kontak di admin siap dipakai — yang belum ada hanya formulir di halamannya.

10.2 Newsletter (Newsletter.php)

- subscribe: validasi email, buat token unsubscribe acak, simpan ke newsletter_subscribers; email yang pernah berhenti diaktifkan kembali. Respons JSON.
- unsubscribe?token=...: berhenti berlangganan; hasil di pages/unsubscribe.php.
- Sama seperti kontak: endpoint berfungsi, tetapi belum ada formulir langganan di halaman mana pun.

10.3 Pencarian (Search.php) dan API (Api.php)

Endpoint	Fungsi
GET /search?q=&category=	Hasil pencarian: berita, video, galeri, unit & halaman (tampilan lama, lihat 5.4)
GET /api/search?q=	Pencarian cepat JSON (min. 2 karakter)
GET /api/units	Data unit + jumlah pendaftar per jenjang, JSON, cache 1 jam (butuh tabel pendaftaran)

10.4 Sitemap (Sitemap.php)

/sitemap.xml dibangkitkan dinamis: halaman statis, halaman TK dan SD, berita, dan video kegiatan. /tk/fasilitas dan /tk/kegiatan (dulu galat 500) sudah diganti /tk/program dan /tk/galeri.

10.5 Pendaftaran Terpadu (Pendaftaran.php)

- index: formulir semua jenjang (TK/SD/SMP/SMA/UCB). submit: validasi, simpan ke pendaftaran; untuk TK/SD juga menyalin ke tabel lamanya. sukses: menampilkan nomor registrasi.
- Berfungsi (lulus uji), tetapi tampil tanpa gaya dan tidak ditautkan dari menu — lihat 5.4.

11. Model & Helper

11.1 Model

Model	Peran
M_data	Model generik: get_data, get_data_where, insert/update/delete_data, dan delete_data_wfoto / delete_data_gfoto (hapus baris + file foto). Setiap operasi menyetel flashdata.
Visitors_log	log_visitor(), get_daily_visits(), get_monthly_visits(), get_yearly_visits()
Contact_model	Dipakai Contact.php (Bagian 16.4)
Buku_model	Dipakai modul Katalog (Bagian 16.4)

⚠ Diperbaiki: Foto Lama Tidak Pernah Terhapus

delete_data_wfoto() dan delete_data_gfoto() dulu menghapus file dari assets/templates/media/avatars/, padahal foto struktur dan galeri diunggah ke uploads/avatars/ dan uploads/galeri/. Akibatnya setiap data yang dihapus meninggalkan file-nya (salah satu sebab file yatim di uploads/, Bagian 13.4). Kini menunjuk folder yang benar, memakai basename() dan is_file().

11.2 Helper (yayasan_helper.php)

Fungsi	Kegunaan
aset(\$path)	URL aset + "?v=" waktu ubah file, agar cache browser ter-refresh saat file berubah
ikon(\$nama, \$ukuran)	Ikon SVG inline
tanggal_id(\$tgl)	Format tanggal Indonesia, mis. "31 Januari 2024"
potong(\$teks, \$n)	Memotong teks dan membuang tag HTML
kategori_berita(), label_kategori()	Kategori berita: Umum, Kegiatan, Pengumuman
foto_struktur(\$foto)	URL foto pejabat di uploads/avatars/, hanya jika file-nya ada
bersihkan_html(\$html) (DIPERBAIKI)	Membuang script/style/iframe/object/embed/form, atribut on*, dan URL javascript:/vbscript:/data: dari HTML isi berita & konten. Dulu hanya "return \$html;"
data_situs_yayasan() (BARU)	Data header/footer situs yayasan (\$unit, \$pengaturan) untuk controller yang tidak mengirimnya (Search, Pendaftaran, Newsletter)

🔴 Mengapa bersihkan_html() Penting

Isi berita ditulis admin lewat CKEditor lalu ditampilkan apa adanya. View pages/baca.php bahkan berkomentar bahwa fungsi ini "membuang blok script ... dan URL berskema javascript:", padahal isinya kosong. Tanpa pembersihan, siapa pun yang memegang akun admin (termasuk akun lama dengan password yang diketahui publik, Bagian 16.1) bisa menyisipkan JavaScript ke halaman publik. Uji: skrip, onerror, onclick, javascript:, dan iframe terbuang; paragraf dan huruf tebal tetap utuh.

12. Basis Data

12.1 Tabel di Dump SQL (u1711594_yayasan_v2.sql)

Tabel	Kolom Utama	Isi di repositori kerja
auth	id_user, username, password, role	KOSONG — dibuat lewat seed_admin
berita	id_berita, judul_berita, isi_berita, tanggal_post, tanggal_update, gambar	5 berita
galeri	id_foto, judul_foto, foto	8 foto
konten	id_konten, judul_konten, sub_judul_konten, isi_konten, jenis_konten	7 blok konten
struktur_organisasi	id_struktur, foto, nama, jabatan	13 pejabat
video_kegiatan	id_video, judul_video, deskripsi, link	7 video
visitor_logs	id, ip_address, visit_date, visit_month, visit_year	KOSONG
buku, pesanan, pesanan_detail	—	Modul Katalog (4 buku)

Dump Disanitasi Sebelum Dipublikasikan Ulang

Dump asli (10 Agustus 2026, dari server produksi) memuat akun admin123 / admin123 dengan role "default" (lolos semua pemeriksaan hak akses) dan adminbuku / adminbuku — password keduanya sama dengan username, dan hash-nya ada di repositori publik. Dump juga memuat 19.455 baris log pengunjung berisi alamat IP (data pribadi). Di repositori kerja, baris akun dan log pengunjung dikosongkan; struktur tabel dan seluruh konten situs tetap utuh. Dump asli di RielViz/CBIM tidak diubah.

12.2 Tabel yang Dipakai Kode tetapi Tidak Ada di Dump

Enam tabel berikut dibuat oleh migration_tabel_tambahan.sql. Kolomnya diturunkan dari perintah insert/update/select di controller dan view.

Tabel	Kolom	Dipakai oleh
pendaftaran	id_pendaftaran (PK), no_registrasi, jenjang, nama_lengkap, nik_nisn, jenis_kelamin, tempat_lahir, tgl_lahir, agama, nama_ortu, pekerjaan_ortu, no_hp, email, alamat, asal_sekolah, catatan, status, tanggal_daftar	Tk, Sd, Pendaftaran, Admin, Api
pendaftaran_sd	id_pendaftaran (PK), nama_lengkap, nisn, jenis_kelamin, tempat_lahir, tgl_lahir, nama_ortu, no_hp, alamat, tanggal_daftar, status	Sd, Pendaftaran, Admin
pendaftaran_tk	id_pendaftaran (PK), nama_lengkap, kelompok, jenis_kelamin, tgl_lahir, nama_ortu, no_hp, alamat, tanggal_daftar, status	Tk, Pendaftaran, Admin
pesan_kontak	id_pesan (PK), nama, email, subjek, pesan, ip_address, status, created_at	Kontak, Admin

Tabel	Kolom	Dipakai oleh
newsletter_subscribers	id_subscriber (PK), email (unik), preferensi, token_unsubscribe, status, created_at	Newsletter, Admin
contact_messages	id (PK), nama, email, subjek, pesan, ip_address, created_at, status	Contact.php

12.3 konten_tk & konten_sd (dibuat otomatis, Bagian 9.4)

Kolom	Tipe
id_konten	INT(11) AUTO_INCREMENT, PRIMARY KEY
judul_konten	VARCHAR(255) NOT NULL
sub_judul_konten	VARCHAR(255) NULL
isi_konten	LONGTEXT NOT NULL
jenis_konten	VARCHAR(50) NOT NULL

12.4 Relasi Data

- Tabel tidak memakai foreign key (kecuali pesanan_detail milik modul Katalog).
- pendaftaran adalah sumber utama PPDB; pendaftaran_sd/tk adalah salinan untuk kompatibilitas.
- konten (situs utama), konten_tk, dan konten_sd adalah tiga tabel terpisah dengan panel admin berbeda.
- konten ber-jenis kontak / alamat dipakai di header & footer seluruh situs utama.

13. Pembersihan Proyek (File Tidak Terpakai)

13.1 Metode

Sebuah file dianggap tidak terpakai hanya bila terbukti: (1) tidak ada rujukan ke path atau nama file-nya di seluruh kode PHP, CSS, JS, dan isi database; (2) rujukan dinamis ikut diperhitungkan, misalnya 'logos/' . \$meta['logo'] (bernilai sd.png atau paud-tk.png) dan 'assets/img/' . \$unit['logo']; dan (3) setelah dihapus, crawler dan uji formulir memberi hasil yang identik dengan kode asli. Pembersihan dilakukan dua tahap; tahap kedua dijalankan setelah bug diperbaiki, karena beberapa rujukan lama ternyata menunjuk ke file yang memang tidak ada.

13.2 Tahap 1 — Sisa Template dan Kode Lama

Yang dihapus	Ukuran	Alasan
application/views/tk/assets/	≈ 298 MB, 2.175 file	Salinan penuh bundle template Metronic di dalam views/tk. Diblokir .htaccess dan tidak dirujuk kode apa pun.
assets/templates/css/, js/, plugins/	± 77 MB	Sisa bundle Metronic (jQuery, DataTables, SweetAlert, CKEditor 4, TinyMCE, dll). Situs memuat yayaan.css; admin memuat admin.css/admin.js dan CKEditor 5 dari CDN.
application/controllers/temp/	4 file	Memuat view 'templates/header' yang tidak ada — galat bila diakses.
application/controllers/Page_backup.php	1 file	Berkas UTF-16; nama class (Page) tidak cocok nama file, tidak bisa di-routing.
application/models/M_auth.php	1 file	Di-load di Auth.php tanpa satu method pun dipanggil (baris load ikut dihapus).
application/views/tk/koneksi.php, kofigurasi.php, login.php, formulir.php	4 file	Sisa situs PHP lama sebelum CodeIgniter; formulir.php hanya mock-up dengan action="#".
extract*.php, update_links.php, create_sd_template.php, check_syntax.php	6 file	Skrip bantu sekali pakai di root; sebagian bisa dijalankan lewat URL karena tanpa penjaga BASEPATH.

13.3 Tahap 2 — Media, Demo, dan Dependensi yang Tidak Dipakai

Yang dihapus	Ukuran	Alasan
assets/templates/media/ dan assets/img/	1.397 file, 56,9 MB	Bendera, ikon duotone, foto stok, ilustrasi demo, logo lama (sd.jpg, paud.jpg, smp.jpg, sma.jpg, gambar-ucb.png, dll.), assets/img/struktur/*.jpg. Tersisa 8 file yang dipakai.
application/views/templates/admin/page.php, drawers.php	280 KB	Halaman demo Metronic; tidak di-load controller mana pun.
node_modules/ (ckeditor4) dan package-lock.json	2.798 file, 17 MB	CKEditor 4 tidak dipakai lagi.

13.4 Sengaja TIDAK Dihapus

- Modul Katalog Buku dan Contact.php — masih bisa diakses lewat URL (keputusan pemilik proyek; Bagian 16.4).
- uploads/ — konten yang dikelola admin. Database produksi bisa merujuk file yang tidak ada di dump, jadi file di sini tidak dihapus walau sebagian tidak dirujuk dump.

Kandidat file yatim di uploads/	Jumlah	Keterangan
uploads/galeri/	10 file, 28,6 MB	Kebanyakan unggahan ganda (nama sama, versi berakhiran "1" yang dipakai)
uploads/berita/	8 file, 12,4 MB	Versi lama gambar berita + new.jpg, new1.jpg, new2.jpg (unggahan uji)
uploads/avatars/	36 file, 3,6 MB	Avatar stok template 150-*.jpg dan foto pejabat lama
uploads/ (akar)	1 file	Satu gambar tanpa rujukan
Total	55 file, 44,6 MB	Cocokkan dengan database produksi sebelum menghapus

13.5 Dampak

Ukuran	Kode asli (d52fdf7)	Repositori kerja
Jumlah file	7.558	460
Ukuran working tree	632 MB	181 MB (174 MB di antaranya uploads/)
application/	300 MB	1,4 MB
assets/	139 MB	3,3 MB
File dihapus	—	7.099 (tahap 1: 2.902, tahap 2: 4.197)

14. Pengujian & Verifikasi

Untuk menjawab pertanyaan "apakah kode ini benar-benar membentuk website Yayasan CBIM tanpa galat?", website dijalankan dan diuji dalam tiga versi: kode asli (RielViz/CBIM d52fdf7), kode setelah pembersihan tahap 1, dan kode akhir di repositori kerja. Situs produksi cbim.or.id tidak diakses sama sekali.

14.1 Lingkungan Uji

Komponen	Detail
PHP	8.4.21 (server bawaan PHP + router yang meniru .htaccess, termasuk blokir application/ & system/)
Database	MariaDB 10.11.14; satu database terpisah per versi kode
Data	Dump u1711594_yayasan_v2.sql + migrasi, ditambah akun uji administrator, admin_tk, admin_sd
Mode	development — agar setiap peringatan PHP dan galat database terlihat di halaman
Peramban	Chromium (Playwright) untuk pemeriksaan visual

14.2 Metode

Jenis uji	Cara kerja
Crawler halaman & aset	Mengunjungi ±50 URL awal (semua rute + halaman yang diketahui) lalu mengikuti setiap tautan internal. Tiap halaman diperiksa status HTTP-nya dan dicari pesan galat CodeIgniter/PHP/database. Setiap CSS, JS, gambar, favicon, dan og:image yang dimuat halaman ikut diperiksa. Dijalankan untuk 4 peran: publik, administrator, admin_tk, admin_sd.
Uji formulir end-to-end	31 skenario: kirim PPDB TK & SD, honeypot, tanpa persetujuan orang tua, tanggal tidak valid, formulir /pendaftaran, kontak, newsletter, login & aksi admin, CRUD panel TK, pembatasan peran. Hasil dicek langsung ke database.
Uji keamanan	8 skenario: isi CSV per peran, ubah status lintas jenjang, sanitasi HTML berita, penghapusan file galeri, path traversal.
Uji instalasi	Database kosong → dump → dua migrasi → seed_admin (dan seed_admin kedua harus ditolak).
Uji backup	php index.php backup run, lalu periksa lokasi file dan apakah bisa diunduh lewat HTTP.
Uji visual	Tangkapan layar halaman kunci di Chromium.
Lint	php -l pada seluruh 123 file PHP aplikasi.

14.3 Ringkasan Hasil

Pemeriksaan	Kode asli	Setelah tahap 1	Kode akhir
Halaman publik bermasalah (dari 89)	33	33	0

Pemeriksaan	Kode asli	Setelah tahap 1	Kode akhir
— di antaranya menampilkan peringatan PHP	20	20	0
Gambar / aset rusak	16	16	0
Halaman admin galat	8 dari 15	8 dari 15	0 dari 42
Uji formulir end-to-end	24/31	24/31	31/31
Uji keamanan	2/8	—	8/8
Galat PHP di log server	—	—	0
File PHP lolos lint	—	—	123/123



Cara Membaca Tabel

Crawler pada kode asli dijalankan dengan dump apa adanya (tanpa 6 tabel yang hilang) — keadaan yang didapat siapa pun yang memasang dari repositori asli. Uji formulir kode asli dijalankan SETELAH tabel tambahan dibuat, agar logika formulirnya bisa diuji. Kolom "Setelah tahap 1" identik dengan kode asli: pembersihan tidak merusak apa pun. Kode akhir diuji dari instalasi baru mengikuti Bagian 3.2. Tiga respons yang tersisa pada crawler kode akhir memang benar: dua halaman 404 untuk alamat yang tidak ada, dan 405 untuk GET ke endpoint yang hanya menerima POST.

14.4 Rincian Uji Formulir & Aksi Admin

Skenario	Kode asli	Kode akhir
TK: halaman /tk/ppdb memuat formulir yang mengarah ke tk/submit_ppdb	GAGAL	Lulus
TK: kirim PPDB valid -> tersimpan di pendaftaran & pendaftaran_tk	Lulus	Lulus
TK: pesan sukses tampil setelah kirim	GAGAL	Lulus
TK: honeypot terisi -> data TIDAK disimpan	Lulus	Lulus
TK: tanpa persetujuan ortu (UU PDP) -> ditolak	GAGAL	Lulus
SD: halaman /sd/ppdb memuat formulir yang mengarah ke sd/submit_ppdb	Lulus	Lulus
SD: kirim PPDB valid -> tersimpan di pendaftaran & pendaftaran_sd	Lulus	Lulus
SD: pesan sukses tampil setelah kirim	Lulus	Lulus
SD: tanggal lahir di masa depan -> ditolak validasi	Lulus	Lulus
/pendaftaran: halaman tampil tanpa error PHP	GAGAL	Lulus
/pendaftaran/submit -> tersimpan & halaman sukses tanpa error	GAGAL	Lulus
kontak/kirim (AJAX) -> tersimpan di pesan_kontak	Lulus	Lulus
newsletter/subscribe -> tersimpan	Lulus	Lulus
newsletter/unsubscribe -> status Unsubscribed, halaman tanpa error	GAGAL	Lulus
Admin: login uji_admin	Lulus	Lulus
Admin: admin/pendaftaran_terpadu tampil tanpa error	Lulus	Lulus

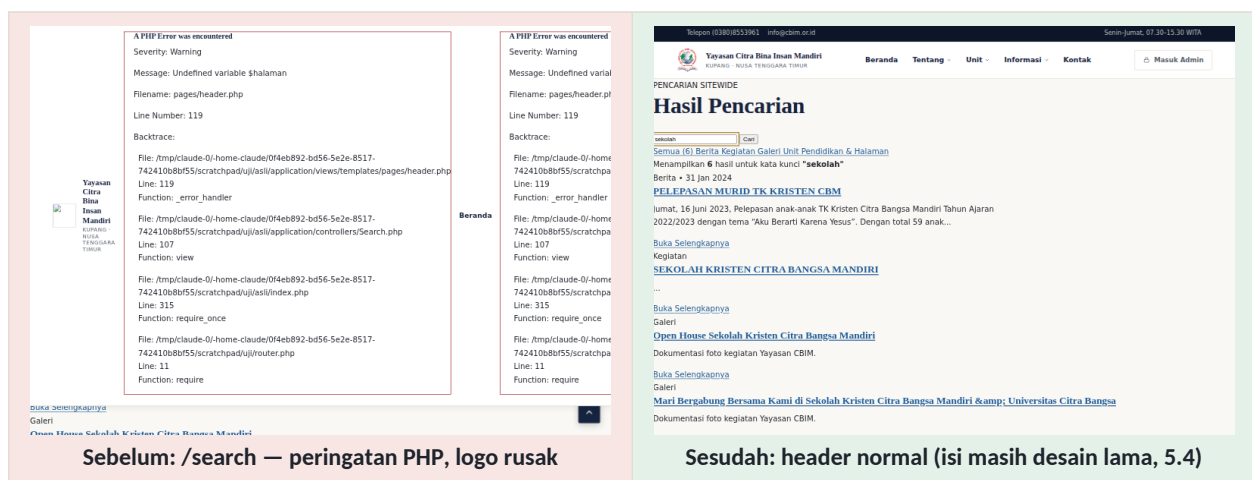
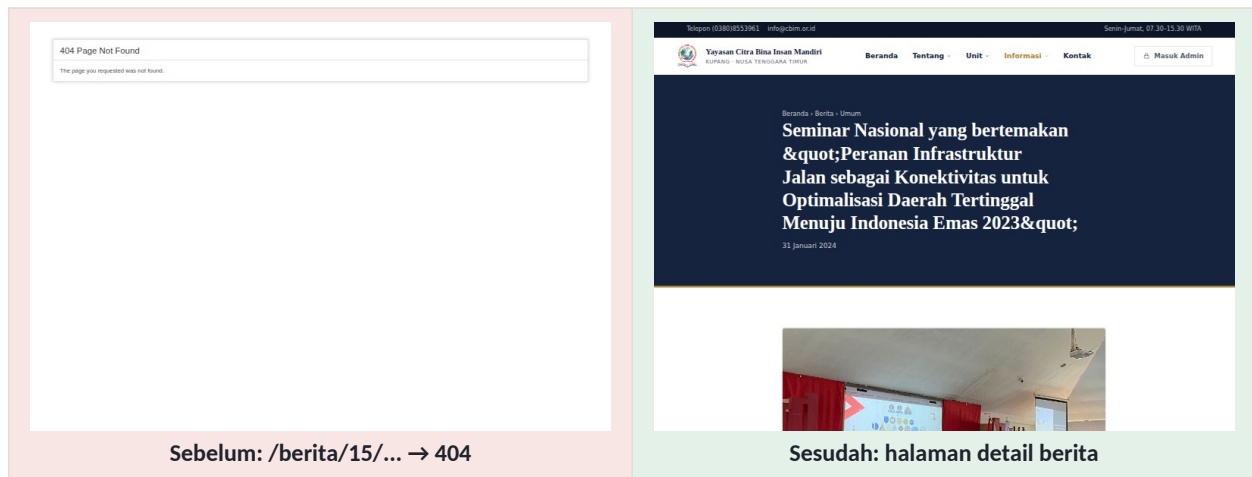
Skenario	Kode asli	Kode akhir
Admin: admin/pesan_kontak tampil tanpa error	Lulus	Lulus
Admin: admin/newsletter tampil tanpa error	Lulus	Lulus
Admin: admin/pendaftaran_sd tampil tanpa error	Lulus	Lulus
Admin: admin/pendaftaran_tk tampil tanpa error	Lulus	Lulus
Admin: pendaftar TK & SD dari formulir unit muncul di Pendaftaran Terpadu	Lulus	Lulus
Admin: ubah status pendaftaran -> Diterima	Lulus	Lulus
Admin: ekspor CSV pendaftaran	Lulus	Lulus
Admin: ubah status pesan kontak	Lulus	Lulus
Admin TK: login uji_tk	Lulus	Lulus
Admin TK: tambah konten	Lulus	Lulus
Admin TK: ubah konten	Lulus	Lulus
Admin TK: hapus konten	Lulus	Lulus
RBAC: akun admin_tk tidak bisa masuk panel admin-sd	Lulus	Lulus
RBAC: akun admin_tk (lewat /auth) ditolak di admin/berita	Lulus	Lulus
RBAC: akun admin_tk TIDAK bisa ekspor CSV seluruh pendaftar	GAGAL	Lulus

14.5 Rincian Uji Keamanan

Skenario	Kode asli	Kode akhir
RBAC: CSV untuk admin_tk hanya berisi pendaftar TK	GAGAL	Lulus
RBAC: admin_tk tidak bisa mengubah status pendaftar SD	GAGAL	Lulus
RBAC: CSV untuk administrator berisi semua jenjang	Lulus	Lulus
Sanitasi: halaman detail berita tampil (200)	GAGAL	Lulus
Sanitasi: <script>, on*, javascript:, <iframe> dibuang dari isi berita	Tak teruji*	Lulus
Sanitasi: format biasa (p, strong, teks) tetap utuh	GAGAL	Lulus
Galeri: hapus data juga menghapus file di uploads/galeri/	GAGAL	Lulus
Path traversal: foto_lama="../../robots.txt" TIDAK menghapus file di luar uploads/	GAGAL	Lulus

* Pada kode asli, halaman detail berita situs utama selalu 404, sehingga sanitasi tidak dapat diamati di sana; bersihkan_html() versi asli memang hanya "return \$html;".

14.6 Bukti Visual



The image shows a registration form for TK Kristen Citra Bangsa. The form is titled 'Formulir Pendaftaran' and includes a sub-header 'Data Calon Siswa'. The form fields are: 'Nama Lengkap Anda *' (with a note 'Sesuai akta kelahiran'), 'Tanggal Lahir *' (with a date picker), 'Jenis Kelamin *' (with a dropdown menu), and 'Pilihan Kelompok' (with a dropdown menu). Below these fields is a section titled 'Data Orang Tua / Wali' with fields for 'Nama Orang Tua / Wali *' and 'No. WhatsApp / HP *' (with a pre-filled number '081234567890'). The form is set against a light orange background with a navigation bar at the top.

Formulir PPDB TK baru di /tk/ppdb#formulir



GALAT 404

Halaman ini tidak ditemukan

Mungkin alamatnya salah ketik, atau halamannya sudah dipindahkan. Coba mulai lagi dari beranda.

[Beranda yayasan](#)[Situs TK](#)[Situs SD](#)**Yayasan Citra Bina Insan Mandiri**

Menyelenggarakan pendidikan Kristen dari jenjang anak usia dini sampai perguruan tinggi, serta layanan kesehatan dan pelatihan bagi masyarakat Kota Kupang.

TENTANG

[Profil yayasan](#)
[Struktur organisasi](#)
[Unit pendidikan](#)
[Kontak](#)

INFORMASI

[Berita](#)
[Kegiatan](#)
[Galeri](#)
[Pendaftaran](#)

UNIT PENDIDIKAN

[TK Kristen Citra Bangsa](#)
[SD Kristen Citra Bangsa Mandiri](#)
[SMP Kristen Citra Bangsa](#)
[SMA Kristen Citra Bangsa](#)

Halaman 404 bergaya situs (pages/empat_nol_empat.php)

15. Perbaikan Bug

Semua masalah berikut sudah ada di kode asli (bukan akibat pembersihan) dan diperbaiki di repositori kerja, commit 85ebf65. Setiap perbaikan diverifikasi ulang dengan uji di Bagian 14.

#	Masalah (sebelum)	Perbaikan	Berkas
1	"Undefined variable \$unit" dan logo rusak di /pendaftaran, /search, /newsletter/unsubscribe (20 halaman)	Header memakai data_situs_yayasan() bila controller tidak mengirim datanya	templates/pages/header.php, yayasan_helper.php
2	Detail berita situs utama selalu 404; tautan dari pencarian/sitemap hanya menampilkan daftar	Rute berita/(:num)/(:any); Page::berita(\$id,\$slug) memuat pages/baca.php; ID hex didekode	routes.php, Page.php
3	Tautan footer "Pendaftaran" (/daftar) 404	Rute + Page::daftar(); kartu unit menuju /tk/ppdb dan /sd/ppdb	routes.php, Page.php, pages/daftar.php
4	Halaman 404 polos bawaan CodeIgniter	404_override → Page::tidak_ditemukan() dengan view empat_nol_empat.php	routes.php, Page.php
5	/page/login galat 500 (view tidak ada)	Dialihkan ke /auth	Page.php
6	/tk/fasilitas dan /tk/kegiatan galat 500, tercantum di sitemap	Dialihkan 301 ke /tk/program dan /tk/galeri; sitemap diperbarui	Tk.php, Sitemap.php
7	Tombol "Daftar sekarang" di beranda TK → pendaftaran.php (404)	Menuju /tk/ppdb#formulir; "Atur kunjungan" menuju /kontak	tk/index.php
8	/tk/ppdb tanpa formulir; tombol → formulir.php (404); pesan hasil tidak tampil	Formulir PPDB TK sesuai validasi controller + pesan sukses/galat	tk/ppdb.php
9	13 foto berita/galeri dan foto kepala sekolah tidak tampil di halaman SD	Jalur diarahkan ke uploads/berita galeri/; logo SD sebagai pengganti sementara	sd/index.php, sd/kegiatan.php
10	Enam tabel tidak ada di dump → galat database di PPDB, kontak, newsletter, API, 7 halaman admin	migration_tabel_tambahan.sql	(berkas SQL baru)
11	Di Linux, backup tersimpan di <web root>/C:/xampp/cbim_backups/ dan bisa diunduh	Path Windows hanya dipakai di Windows	Backup.php
12	CSV pendaftar semua jenjang bisa diunduh admin unit; admin unit bisa ubah status jenjang lain; role lain melihat semua	_jenjang_peran() menyaring daftar, CSV, dan ubah status	Admin.php
13	foto_lama / gambar_lama dari POST langsung dipakai di unlink() (terbukti menghapus robots.txt)	basename() + is_file()	Admin.php
14	Hapus data struktur/galeri tidak menghapus file fotonya	Folder diarahkan ke uploads/avatars galeri/	M_data.php
15	bersihkan_html() tidak membersihkan apa pun	Pembersihan berbasis DOM (script, iframe, on*, javascript:)	yayasan_helper.php

#	Masalah (sebelum)	Perbaikan	Berkas
16	robots.txt tidak menutup /admin-tk dan /admin-sd	Ditambahkan Disallow	robots.txt
17	Dump publik memuat akun ber-password lemah dan 19.455 alamat IP pengunjung	Baris akun & log dikosongkan	u1711594_yayasan_v2.sql
18	README berisi judul proyek lain	Ditulis ulang: instalasi, akun, backup, hasil uji	README.md

16. Keamanan & Temuan yang Belum Ditindaklanjuti

Hal-hal berikut ditemukan tetapi tidak diubah, karena menyangkut server produksi, keputusan konten, atau perubahan desain yang lebih besar. Diurutkan dari yang paling mendesak.

16.1 KRITIS — Akun Lama di Database Produksi

Segera Periksa di cbim.or.id

Dump yang diambil dari server produksi (10 Agustus 2026) memuat admin123 / admin123 (role "default", lolos semua pemeriksaan hak akses) dan adminbuku / adminbuku. Kecocokan password ini dibuktikan pada salinan lokal dump, bukan pada situs produksi. Bila akun ini masih ada di produksi, siapa pun bisa masuk ke panel admin. Tindakan: hapus kedua akun, ganti password akun admin lain, lalu periksa isi berita/konten dari kemungkinan sisipan skrip.

```
DELETE FROM auth WHERE username IN ('admin123', 'adminbuku');
```

Periksa Juga Folder "C:" di Web Root Produksi

Bila backup/run pernah dijalankan di server produksi (Linux) sebelum perbaikan #11, dump database tersimpan di <web root>/C:/xampp/cbim_backups/. Pindahkan ke luar web root atau hapus.

16.2 Proteksi CSRF Nonaktif

`config['csrf_protection'] = FALSE`. Semua form admin (hapus, ubah status, tambah konten) rentan Cross-Site Request Forgery. Saran: aktifkan dan tambahkan token CSRF ke setiap form (termasuk formulir AJAX).

16.3 Judul Ter-escape Ganda (", &)

Panel admin menyimpan input setelah `htmlspecialchars()`, lalu view meng-escape lagi saat menampilkan. Akibatnya berita #15 tampil dengan judul berisi """ dan satu foto galeri berisi "&". Perbaiki yang benar menyentuh semua form admin (simpan apa adanya, escape saat tampil) plus pembersihan data lama, sehingga tidak dilakukan di sini.

16.4 Modul yang Dipertahankan atas Keputusan Pemilik

- Katalog Buku (Katalog.php, Buku_model.php, 7 view) — toko buku sederhana di luar cakupan yayasan, bisa diakses di /katalog dan tercantum di sitemap serta hasil pencarian.
- Contact.php + Contact_model.php — komentarnya menyebut `POST /api/contact`, padahal rute `api/(any)` mengarah ke `Api.php`; URL yang benar-benar aktif adalah `/contact/submit`, dan tidak ada halaman yang memakainya.

16.5 Fitur Setengah Jadi

- Halaman /pendaftaran dan /search tampil tanpa gaya (Bagian 5.4).
- kontak/kirim dan newsletter/subscribe berfungsi tetapi belum punya formulir di halaman mana pun (Bagian 10).
- Halaman PPDB TK: tombol "Login Pendaftar" mengarah ke login admin; alur menyebut "Buat Akun" dan "Unggah Berkas" yang tidak tersedia (Bagian 6.3).

- Belum ada menu untuk mengelola akun admin (Bagian 3.6).

16.6 Catatan Teknis Lain

- Rate limit PPDB dan login berbasis session sehingga bisa dilewati dengan membuang cookie; rate limit Kontak.php sudah berbasis IP di database dan bisa dijadikan pola.
- delete_berita() menghapus baris berita tetapi tidak file gambarnya.
- composer.json mencantumkan phpmailer, tetapi tidak ada kode yang memakainya dan tidak ada folder vendor/.
- 55 file di uploads/ (44,6 MB) tidak dirujuk dump — cocokkan dengan database produksi (Bagian 13.4).

16.7 Praktik Baik yang Sudah Ada

Area	Praktik
Password	password_hash() / password_verify() (bcrypt)
Login	Rate limit, waktu respons seragam, regenerasi session ID
PPDB & Kontak	Honeypot, rate limit, validasi server, persetujuan orang tua/wali (UU PDP)
Backup	Nama file acak, permission 0600, rotasi 30 hari
Header HTTP	X-Content-Type-Options, X-Frame-Options, X-XSS-Protection, Referrer-Policy di .htaccess
Akun pertama	seed_admin hanya lewat CLI, password acak, hanya bila tabel auth kosong

17. Panduan Pemecahan Masalah

Masalah	Kemungkinan Sebab & Solusi
"Table '...pendaftaran' doesn't exist" (atau pesan_kontak, newsletter_subscribers)	migration_tabel_tambahan.sql belum dijalankan (Bagian 3.4).
Login /admin-tk atau /admin-sd selalu gagal walau password benar	Kolom auth.role masih ENUM. Jalankan migration_admin_tk_sd.sql (Bagian 3.3), lalu pastikan role akun tepat admin_tk / admin_sd.
seed_admin menjawab "Dibatalkan: tabel 'auth' sudah berisi ... user"	Memang dirancang begitu: seeder hanya untuk instalasi baru. Buat akun tambahan lewat SQL (Bagian 3.6).
Galat database atau peringatan PHP tampil ke pengunjung	CI_ENV belum diset 'production' (Bagian 1.3).
Halaman /admin-tk/profil galat "table doesn't exist"	User database tidak punya hak CREATE TABLE; jalankan bagian opsional migration_admin_tk_sd.sql secara manual.
Backup tidak muncul di cbim_backups/	Folder induk web root tidak bisa ditulis; Backup.php otomatis memakai uploads/backups/ (dikunci .htaccess). Di Windows: C:/xampp/cbim_backups/.
Ada folder bernama "C:" di web root server Linux	Sisa bug backup lama (#11). Pindahkan isinya ke luar web root, lalu hapus.
Foto yang baru diunggah tidak tampil	Periksa izin tulis uploads/avatars, uploads/berita, uploads/galeri.
Judul berita menampilkan " atau &#amp;	Escape ganda pada data lama (Bagian 16.3). Perbaiki judul lewat SQL atau panel admin.
Halaman /pendaftaran atau /search tampil tanpa gaya	View desain lama (Bagian 5.4).
Backup lama tidak ikut terhapus	Rotasi hanya menyentuh db_*.sql.gz dari backup/run, bukan unduhan manual backup/database.

18. Referensi & Sumber Daya

Repositori kerja: github.com/ArvidKennethG/cbim

Kode sumber asli: github.com/RielViz/CBIM

[CodeIgniter 3 User Guide](#)

[CodeIgniter 3 \(source resmi\)](#)

[CKEditor 5 Documentation](#)

[UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi](#)

— Akhir Dokumen —